



File No.: EXP202206677

RESOLUTION OF FILE OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: On June 7, 2022, a complaint was filed with the Spanish Agency for Data Protection against RESIDENCIAS DEL BUEN RETIRO S.L., and the CANTABRIAN HEALTH SERVICE.

The reasons on which the complainant bases the complaint are as follows:

After receiving a call from his ex-wife, which made him suspect unauthorized access to his medical history, he requested access to the list of accesses to his medical history from May 17, 2016, to May 17, 2021, from the Primary Care Management of the claimed Health Service. From the documentation obtained, he determines consultations of his medical history from two healthcare centers that have no justification: "****CENTER.1" and "****CENTER.2".

By means of a written communication dated October 4, 2021, he informed the claimed Health Service of the events that occurred with the Geriatric Residence ***CENTER.1, having received no response. Additionally, through a burofax, dated March 14, 2022, he directed a written communication to the Geriatric Residence ***CENTER.1 informing them of the unauthorized accesses to his medical history. He states that the residence contacted him and informed him that it is not possible for the physician of the residence to have accessed his medical history at those dates and times.

On the other hand, he claims that on May 7, 2021, he went to the Health Center ***CENTER.2 to undergo a PCR test, and on the same day, his ex-wife called him to confront him about the test he had just taken, stating that three friends of his ex-wife work at that health center.

Relevant documentation provided by the complainant:

- Two Reports issued by the Primary Care Management of the accesses from May 17, 2016, to May 17, 2021, where the Centers are listed: ***CENTER.1, ***CENTER.3, and C.S. ***CENTER.2.
- Proof of submission of the written communication addressed to the Management Directorate of the Cantabrian Health Service dated October 4, 2021, requesting the identity of the individuals who accessed the medical history from the GERIATRIC RESIDENCE OF ***CENTER.1 on specific dates.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/6

- Burofax addressed to the GERIATRIC RESIDENCE OF ***CENTER.1, dated March 14, 2022.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the complaint was forwarded to the claimed party, so that it could proceed to its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding to the Cantabrian Health Service, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on June 14, 2022, as evidenced by the acknowledgment of receipt in the file.

The forwarding to the GERIATRIC RESIDENCE OF ***CENTER.1, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was returned with the legend "unknown," as evidenced by the acknowledgment of receipt in the file.

The forwarding was reiterated to the GERIATRIC RESIDENCE OF ***CENTER.1, resulting in a return with the legend "Absent in delivery," as evidenced by the acknowledgment of receipt in the file.

The CANTABRIAN HEALTH SERVICE (hereinafter SCS) proceeded to respond to the request made in the complaint filed by the complainant with the Agency, providing the clinical access history as

stipulated in Article 41.1 of the Cantabria Law 7/2002, of December 10: "The patient has the right to access the documentation of their medical history and to obtain a copy of the data contained therein. It is the responsibility of healthcare centers to regulate the procedure to guarantee access to the medical history."

After this response, the complainant requests to know the identity of the individuals who accessed his medical history, and the SCS did not provide this information as it indicates that, according to the criteria expressed by the AEPD in various proceedings, the right of access does not legitimize knowing who the individuals are that access their medical history. (In this regard, the SCS cites the Report of the Legal Cabinet Consultation AEPD 0003/2021).

The SCS states that professionals can work remotely and therefore remote access from corporate portable devices to the medical history of their patients is allowed within clinical and care processes. The professionals of the SCS have a duty of confidentiality and confidentiality agreements, and access to information for purposes other than care within their professional practice is prohibited.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/6

The SCS states that, given the potential seriousness of these facts, a reserved information file is opened to determine under what conditions and circumstances these accesses to the medical history by SCS professionals have occurred.

THIRD: On September 7, 2022, in accordance with Article 65 of the LOPDGDD, the complaint submitted was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On December 23, 2022, a request for information was sent to the SCS regarding the facts subject to the complaint.

In relation to this request, the SCS submitted a document indicating that:

"On December 15, the medical inspection concluded the reserved information file, determining that the accesses are inherent to their professional and care relationship with said patient, therefore no file should be opened against the professionals."

LEGAL GROUNDS

I

Competence

In accordance with the functions that Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) confers on each control authority and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Security of processing

Article 32 of the GDPR stipulates the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

III

Principles relating to processing

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

IV

Conclusion

The complaint submitted refers to the unjustified access to the medical history of the complainant by healthcare personnel providing services at "****CENTRO.1" and "****CENTRO.2," dependent on the SCS.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Law 41/2002, of November 14, regulating patient autonomy and rights and obligations regarding information and clinical documentation, in its Article 16 dedicated to the uses of the clinical history, states:

- 1. The clinical history is an instrument primarily intended to guarantee adequate assistance to the patient. The healthcare professionals at the center who perform the diagnosis or treatment of the patient have access to the clinical history as a fundamental tool for their proper assistance.
- 2. Each center shall establish methods that allow access to the clinical history of each patient by the professionals assisting them at all times.
- 3. Access to the clinical history for judicial, epidemiological, public health, research, or teaching purposes is governed by the provisions of the current legislation on personal data protection, and by

Law 14/1986, of April 25, General Health, and other applicable regulations in each case. Access to the clinical history for these purposes requires the preservation of the patient's personal identification data, separated from clinical-assistance data, so that, as a general rule, anonymity is ensured, unless the patient has given their consent to not separate them.

The exceptions are the research cases provided for in section 2 of the seventeenth additional provision of the Organic Law on Personal Data Protection and Guarantee of Digital Rights.

Also exempted are the cases of judicial authority research in which the unification of identifying data with clinical-assistance data is deemed essential, in which case the provisions of the judges and courts in the corresponding process shall apply. Access to the data and documents of the clinical history is strictly limited to the specific purposes of each case.

When necessary for the prevention of a serious risk or danger to public health, the health administrations referred to in Law 33/2011, of October 4, General Public Health, may access the identifying data of patients for epidemiological or public health protection reasons. Access must be carried out, in any case, by a healthcare professional subject to professional secrecy or by another person also subject to an equivalent obligation of secrecy, following justification by the Administration requesting access to the data.

4. The administrative and management staff of healthcare centers may only access the data of the clinical history related to their own functions.

5. Properly accredited healthcare personnel who perform inspection, evaluation, accreditation, and planning functions have access to clinical histories in the fulfillment of their duties to verify the quality of care, respect for patient rights, or any other obligation of the center in relation to patients and users or the healthcare administration itself.

6. Personnel accessing the data of the clinical history in the exercise of their functions are subject to the duty of confidentiality.

7. The Autonomous Communities shall regulate the procedure to record access to the clinical history and its use.

Article 32 of the GDPR establishes the principle of "data security," imposing on the data controller and processor the obligation to adopt technical and organizational measures that guarantee it, adding, among other requirements in section 4, that such measures aim to prevent, among other things, 6/6

other aspects, unauthorized access.

The respondent has reported the following regarding security measures:

- They maintain a record of access by healthcare professionals to the clinical history (HC), in compliance with the traceability obligations imposed by Royal Decree 3/2010, of January 8, which regulates the National Security Scheme, as they have been able to verify the accesses made by healthcare professionals.

- Access to the claimant's HC is inherent to their professional and care relationship with that patient; a conclusion reached after opening a reserved information file to determine under what conditions and circumstances such access to the clinical history by SCS professionals has occurred.

Therefore, it has not been demonstrated that the actions of the respondent as the entity responsible for the processing have not been in accordance with the data protection regulations analyzed in the previous paragraphs.

In accordance with what has been stated by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to the CANTABRIAN HEALTH SERVICE and to the claimant.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as prescribed by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this

resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and in section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-020323

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es